

CVE-2026-24858

FortiOS/FortiWeb Authentication Bypass CSS 9.8 CRITICAL Authorized Lab Testing Only

Slide 1 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Executive Summary

Critical authentication bypass vulnerability affecting tens of thousands of organizations worldwide. Attackers can gain complete administrative access in milliseconds without credentials.

Slide 2 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Vulnerability Overview

- JWT 'none' Algorithm Bypass (CWE-347) • SAML Signature Bypass (CWE-295) • No Cryptographic Verification

Slide 3 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Affected Versions: FortiOS

Vulnerable: 8.0.0, 8.0.1, 8.0.2, 8.0.3 Fixed in: FortiOS 8.0.4 and later Impact: Firmware update required on all affected devices

Slide 4 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Affected Versions: FortiWeb

Vulnerable: 7.0.x, 7.2.x, 7.4.x, 8.0.x Fixed in: FortiWeb 7.2.4, 7.4.2, 8.0.1+ Impact: Complete WAF bypass possible

Slide 5 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

JWT Attack Vectors (Overview)

Endpoint: /api/auth/login Method: POST Parameter: Authorization: Bearer Vulnerability: No algorithm verification before token processing

Slide 6 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

JWT 'none' Algorithm Exploit

Header: {"alg": "none", "typ": "JWT"} Payload: {"admin": true, "username": "attacker", "exp": 9999999999} Why It Works:
Server accepts 'none' algorithm, no signature required, claims processed without verification

Slide 7 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

JWT Signature Verification Failure

Correct Flow: Extract algorithm → Retrieve key → Verify signature → Process claims
Vulnerable Flow: Extract claims → Process immediately → Skip verification → Accept 'none' algorithm

Slide 8 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

SAML Attack Vectors

Endpoint: /api/auth/saml Method: POST Payload: SAML Assertion (XML) Vulnerability: No signature verification

Slide 9 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

SAML Signature Bypass Details

No Signature Tag = Complete Bypass Server accepts assertion without verification Attacker can set admin=true in unsigned SAML

Slide 10 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

SAML XXE Vulnerability Potential

If XML parsing is not properly configured: • Local file disclosure • Denial of Service (Billion Laughs) • SSRF attacks • Remote code execution (chained)

Slide 11 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Authentication Flow Compromise

Normal Flow: Credentials → Validation → JWT issued → Token verified → Claims processed
Compromised Flow: Attacker creates token → Server skips validation → Malicious token accepted

Slide 12 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Technical Exploitation Walkthrough

1. Target enumeration → Identify FortiOS 8.0.x 2. Craft malicious JWT → alg: 'none', admin: true 3. Send to /api/auth/login → Bearer token 4. Server processes without verification 5. Admin session created instantly

Slide 13 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Stage 1: Reconnaissance

Request: GET /health Response: {"product":"FortiOS","version":"8.0.2","build":"Build 0355"}

Slide 14 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Stage 2: JWT Bypass

POST /api/auth/login with malicious JWT token Time: 0.005 seconds

Slide 15 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Stage 3: SAML Bypass (Alternative)

POST /api/auth/saml with unsigned SAML assertion Alternative attack vector

Slide 16 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Stage 4: Verification

GET /api/admin/info Response: {"admin": true, "username": "admin", "authenticated": true}

Slide 17 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Post-Exploitation Capabilities

- Modify firewall rules & policies
- Create backdoor admin accounts
- Export configurations & credentials
- Modify VPN settings
- Access network traffic logs
- Install persistent backdoors

Slide 18 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Impact Assessment & Statistics

Global Impact: Affects tens of thousands of organizations Industries: Finance, Healthcare, Government, Critical Infrastructure Attack Difficulty: Trivial Detection: Low

Slide 19 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

CVSS v3.1 Scoring: 9.8 CRITICAL

AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Slide 20 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Remediation Strategies

1. Identify all affected FortiOS/FortiWeb instances 2. Isolate from direct internet access 3. Enable strict authentication logging 4. Apply patches: FortiOS 8.0.4+, FortiWeb 7.2.4+

Slide 21 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Detection & Defense Mechanisms

Defense: WAF, IDS/IPS, Network segmentation, API rate limiting Detection: Unusual auth patterns, JWT with alg='none', Admin account creation

Slide 22 of 23 | CVE-2026-24858 | Authorized Lab Testing Only

Legal Notice & Questions

AUTHORIZED LAB TESTING ONLY 90-day Embargo on Public Disclosure For authorized security research and educational demonstrations only

Slide 23 of 23 | CVE-2026-24858 | Authorized Lab Testing Only